

Table of Contents

M365 BEC IR: Script Quick Reference (repo edition)	1
Playbook in one line	1
First 15 minutes.....	2
Setup and teardown	2
Hydra-Collect run order (09-Hydra-Collect.ps1)	2
Most-used collection scripts	3
Log processing pipeline (00-08)	5
Pivot pattern	5
Posture and hardening (89-93).....	6
Optional heavy-hitters (invoked within Hydra)	6
References.....	6

M365 BEC IR: Script Quick Reference (repo edition)

Investigating and Responding to Microsoft 365 Account Compromise on a Shoestring

DEF CON 34 workshop handout. Assumes you have the **M365IRScripts** collection (MIT-licensed): <https://github.com/bitpusher2k/M365IRScripts>

This card covers the most commonly used scripts: what to run, in what order, with which options. For the equivalent native module commands (no repo needed), see the companion "Native PowerShell" handout.

Scripts and commands are provided as-is. Use at your own risk. None of this is legal advice. For legal advice, talk to a lawyer.

Playbook in one line

Contain -> Collect -> Triage -> Pivot -> Expand -> Remediate -> Harden -> Report

Chronology is the first element of induction; topology is the second. Correlate events by proximity in time and proximity in source.

Contain if wire fraud is in progress, admin compromise is suspected, a phishing blast already went out, or compromise is confirmed. **Observe first** if the threat is already contained by circumstance, or you cannot yet confirm compromise and disruption to end users outweighs suspect evidence.

First 15 minutes

1. Lock down known affected accounts: reset password and revoke sessions (25-Lockdown-Account.ps1).
2. Run 09-Hydra-Collect.ps1 for automated baseline collection.
3. Start review with sign-in logs, SuspiciousInboxRulesForManualReview_*.csv (script 17), and Entra ID risk (script 24, if available).
4. Lock down any additionally discovered accounts, then continue with targeted search and review.

AD-sync gotcha. If the account is AD-synced and password writeback is **not** enabled, Update-MgUser -AccountEnabled:\$false / password reset appear to succeed but Entra re-syncs the old password and re-enables the account on the next sync cycle. Reset the password **in on-prem AD** and force a sync.

Setup and teardown

Script	Purpose
00-Update-M365Modules.ps1	Install/update all needed M365 modules.
01-Connect-M365Modules.ps1	Connect Exchange Online, IPPS, and Microsoft Graph. Prerequisite for everything else.
09-Hydra-Collect.ps1	Run the standard collection set in sequence.
99-Disconnect-M365Modules.ps1	Disconnect all modules when finished.

Required modules (v5): ExchangeOnlineManagement, Microsoft.Graph, Microsoft.Graph.Beta, Microsoft-Extractor-Suite. Keep module versions up-to-date, remove old versions, and PowerShell 7.x is recommended to avoid some sign-in issues.

Tip: set Edge as the default browser on the IR workstation so PowerShell auth prompts open there. Working across multiple tenants? Set Edge to clear all data on close.

Reports write to Desktop\Investigation\<tenant-primary-domain>. Override the base path with **-OutputPath**. -NoExplorer suppresses auto-opening the output folder.

Hydra-Collect run order (09-Hydra-Collect.ps1)

v5.0.0 "DEF CON edition" runs script set in this order:

- 10 tenant info
- 18 inbox rule changes (first pass)
- 13 all email addresses
- 14 password report
- 17 suspicious inbox rules
- 19 all inbox rules
- 22 enterprise apps

```

20 forwarding
21 mailbox permissions
23 Defender
24 Entra ID risk
90 MFA report
91 CAP report
93 Secure Score
[optional] 15 UAL IR events
[optional] 16 all UAL entries in range
18 inbox rule changes (second pass, often catches what the first misses)
12 UAL sign-in
11 Entra sign-in/audit (P1)
[optional] Invictus Extractor Suite cmdlets
[optional] CrowdStrike CRT

```

Note the ordering: **11 and 12 (the sign-in log pulls) run at the end**, since they can take a long time, and you may already have sign-in logs exported from GUI. A set of admin consoles is also opened in Edge.

Invocation:

```

# 7-day window Skip the interactive optional prompts and do not pop Explorer
powershell -executionpolicy bypass -f .\09-Hydra-Collect.ps1 -OutputPath
"Default" -DaysAgo 7 -SkipOptional -NoExplorer

```

Most-used collection scripts

Common parameters: -OutputPath "Default", time window via -DaysAgo "N" or -StartDate/-EndDate, and -UserIds for user-scoped scripts. Run 01-Connect-M365Modules.ps1 first.

#	Script	Use	Key options
10	10-Get-BasicTenantInformation.ps1	Ground truth: tenant, licensing, UAL-enabled. Run first on an unfamiliar tenant.	-OutputPath
12	12-Search-UnifiedAuditLogSignIn.ps1	Sign-ins from the UAL (up to 180-day retention).	-UserIds "All" -DaysAgo "10"
17	17-Search-MailboxSuspiciousRules.ps1	Inbox rules flagged by heuristics. Run FIRST and LAST.	-OutputPath
18	18-Search-InboxRuleChanges.ps1	UAL history of rule changes (finds rules even after deletion).	-DaysAgo "10"
19	19-Get-AllInboxRules.ps1	All inbox rules across	-OutputPath

		all mailboxes.	
20	20-Get-ForwardingSettings.ps1	Mailboxes with a forwarding address set.	-OutputPath
21	21-Get-MailboxPermissions.ps1	Non-standard mailbox permissions (FullAccess, SendAs, SendOnBehalf).	-OutputPath
22	22-Get-EnterpriseApplications.ps1	Enterprise apps, newest first. Watch for known-bad OAuth apps.	-OutputPath
24	24-Get-EntraIDRisk.ps1	Recent Entra ID risk detections.	-OutputPath
25	25-Lockdown-Account.ps1	Revoke sessions, random password, block sign-in. See AD-sync gotcha.	-UserIds "user@contoso.com"
26	26-Revoke-SuspiciousOAuthConsent.ps1	Enumerate and optionally revoke OAuth2 delegated grants.	-OutputPath
27	27-Get-ConsentGrantAudit.ps1	UAL "Consent to application" history.	-DaysAgo "30"
33	33-Get-UserMessageTrace.ps1	Recent in/out mail for a user (uses Get-MessageTraceV2).	-UserIds - DaysAgo "10"
34	34-Get-MailboxAuditLog.ps1	Mailbox audit activity (via Search-UnifiedAuditLog -RecordType ExchangeItem).	-UserIds - DaysAgo "10"
36	36-Search-UALActivityByIPAddress.ps1	All UAL entries for a set of IPs.	-IPs "1.1.1.1,8.8.8.8" -DaysAgo "10"
37	37-Search-UALActivityByUser.ps1	All UAL entries for a set of users.	-UserIds - DaysAgo "10"
39	39-Search-UALMailItemsAccessedByUser.ps1	MailItemsAccessed records. Filter by malicious IP/SessionID.	-UserIds - DaysAgo "10"
40	40-Search-UALEmailSendByUser.ps1	Send/SendAs/SendOnBehalf ops (find the outbound blast).	-UserIds - DaysAgo "30"

41	41-Get-TransportRules.ps1	Export all transport (mail flow) rules.	-OutputPath
43	43-Check-MailboxAuditConfig.ps1	Verify AuditEnabled and adequate AuditLogAgeLimit.	-OutputPath

Example invocation pattern:

```
# Lock down one account, then pull its mail-access and send history
powershell -executionpolicy bypass -f .\25-Lockdown-Account.ps1 -OutputPath "Default" -UserIds "compromised@contoso.com"
powershell -executionpolicy bypass -f .\39-Search-UALMailItemsAccessedByUser.ps1 -OutputPath "Default" -UserIds "compromised@contoso.com" -DaysAgo "10"
powershell -executionpolicy bypass -f .\40-Search-UALEmailSendByUser.ps1 -OutputPath "Default" -UserIds "compromised@contoso.com" -DaysAgo "30"
```

Log processing pipeline (00-08)

Turn raw M365 CSV/JSON exports into analyst-friendly files. Each has a .bat shim for drag-and-drop.

Script	What it does
02-ProcessEntraSignInLog.ps1	Re-orders columns, splits date/time, splits city/region/country.
03-ProcessEntraAuditLog.ps1	Normalizes the Entra audit log CSV.
05-ProcessUnifiedAuditLogFlatten.ps1	Flattens nested AuditData JSON into filterable columns.
06-Lookup-IPInfoCSV.ps1	Enriches an IP column with ASN/ISP/geolocation.
07-ProcessObjectFlatten.ps1	Flattens a JSON file into CSV.
08-SelectUniquePairsCSV.ps1	Unique row pairs from two columns (e.g. IP + SessionID).

Sign-in triage: export sign-ins -> 02 -> 06 -> open in Excel with the **ExcelMacros** workbook (<https://github.com/bitpusher2k/ExcelMacros>).

Pivot pattern

Use 08-SelectUniquePairsCSV.ps1 to reduce a user's sign-in history to unique (IP, SessionID) pairs, which quickly reveals all attacker sessions. Then run 36 (by IP) and 37 (by user): does that IP appear in anyone else's logs? Did the same actor touch another account? When a new IOC surfaces, re-run the targeted scripts and re-pivot.

Posture and hardening (89-93)

Script	Purpose
89-Get-MFAPostureAudit.ps1	Reports how MFA is enforced tenant-wide: Security Defaults state, CA policies enforcing MFA (native vs third-party custom controls), federated domains, and per-user registration, with an overall posture summary. Read-only companion to 90/91.
90-Get-MFAReport.ps1	MFA settings per account via Graph.
91-Get-CAPReport-P1.ps1	Current Conditional Access Policies and Named Locations (needs P1).
92-Create-ConditionalAccessPolicies-P1.ps1	Back up current CA/Named Locations and stage a recommended baseline in report-only (P1; some need P2).
93-Get-SecureScoreInformation.ps1	Retrieve M365 Secure Score.

Start Conditional Access in **report-only**; never flip straight to enforce. From Secure Score, pick the top three remediations by impact-to-effort ratio.

Optional heavy-hitters (invoked within Hydra)

- **Invictus IR Microsoft Extractor Suite** cmdlets: Get-EntraSecurityDefaults, Get-TransportRules, Get-SecurityAlerts, Get-AdminUsers, Get-MailboxAuditStatus, Get-OAuthPermissionsGraph, Get-MFA.
- **CrowdStrike Reporting Tool for Azure (CRT)**: federation config/trust, client-access settings, forwarding, delegates, audit-bypass, GAL-hidden mailboxes, admin audit logging config.

References

- M365IRScripts: <https://github.com/bitpusher2k/M365IRScripts>
- ExcelMacros: <https://github.com/bitpusher2k/ExcelMacros>
- Microsoft, Responding to a compromised email account: <https://learn.microsoft.com/en-us/defender-office-365/responding-to-a-compromised-email-account>
- Invictus Extractor Suite: <https://github.com/invictus-ir/Microsoft-Extractor-Suite>
- CrowdStrike CRT: <https://github.com/CrowdStrike/CRT>

Companion to the DEF CON 34 workshop "Investigating and Responding to M365 Account Compromise on a Shoestring."